🌐 Module 06: API and Java Web Token Penetration Testing

```
# Exercise 03: Scanning and Identifying Vulnerabilities in APIs
```

Scenario

Automated web application security scanners frequently encounter limitations when auditing modern API architectures due to dynamic routing, stateless authentication tokens (such as JWTs), and complex request payloads. Black-box scanners testing from the outside fail to reach authenticated API endpoints without contextual session mapping.

The OWASP **crAPI** (completely Restful Application Programming Interface) platform is designed to highlight critical API vulnerabilities. By using **OWASP ZAP (Zed Attack Proxy)** to manually explore the application, record authenticated session tokens, and include authenticated endpoints into the **Default Context**, penetration testers can launch targeted **Active Scans** (**Active scan**) against internal API endpoints.

In this exercise, we deploy crAPI on Ubuntu using Docker Compose (`docker-compose.yml`), modify service port bindings (`crapi-web` and `mailhog`), establish authenticated sessions via ZAP's manual browser, add the target to ZAP's Default Context, and perform an **Active scan** to uncover critical flaws such as Remote File Inclusion (RFI).

Objective

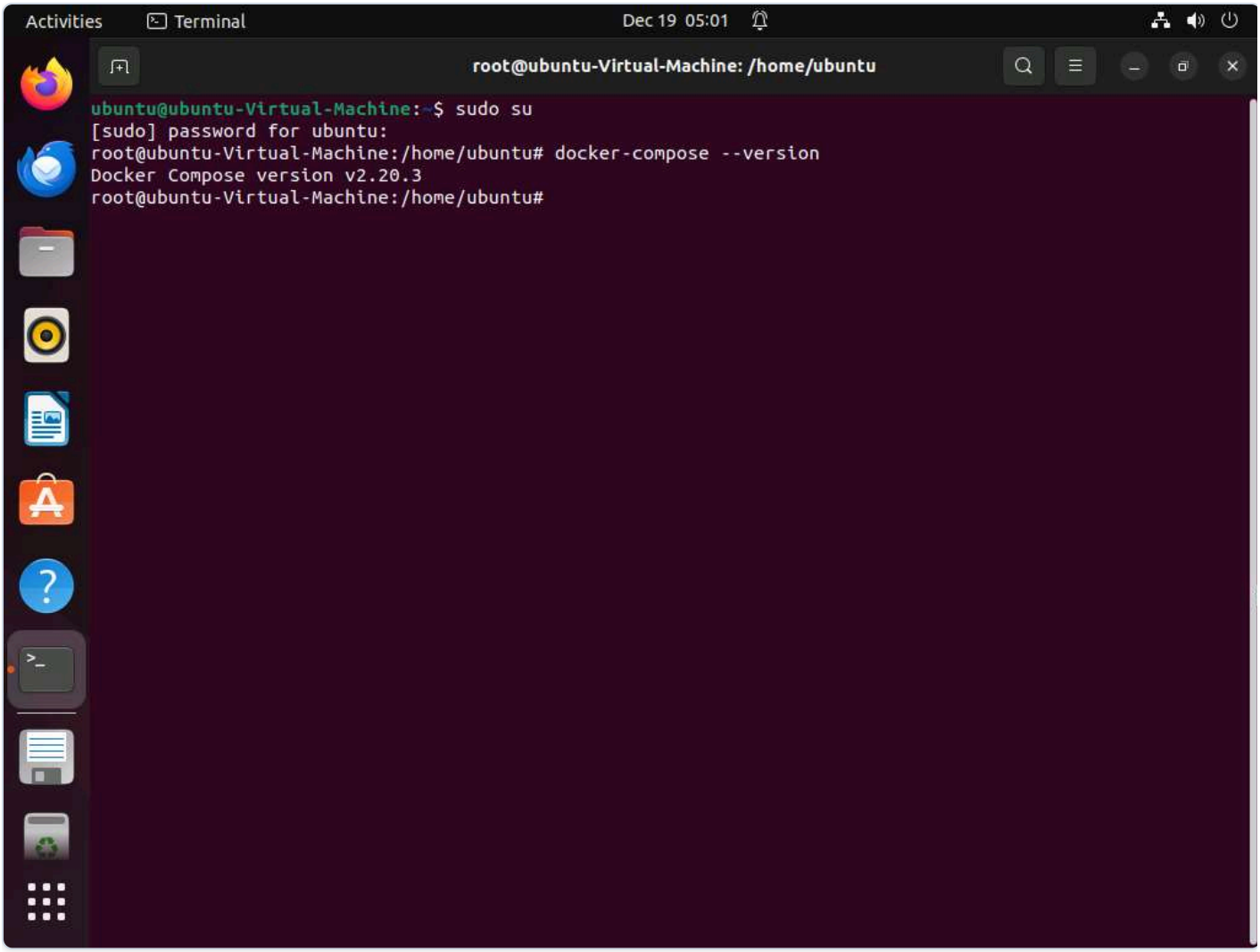
The objective of this lab is to help students learn how to:
- Deploy and configure the OWASP crAPI vulnerable microservice suite using Docker Compose
- Perform authenticated manual site exploration using OWASP ZAP's built-in Chromium browser
- Define target scope by mapping authenticated API routes into OWASP ZAP's **Default Context**
- Execute authenticated automated vulnerability assessments using OWASP ZAP **Active Scan** (**Active scan**)
- Analyze scanner findings in ZAP's Alerts tab to identify critical flaws like Remote File Inclusion (RFI)

Task 1: Deploy crAPI and Perform Authenticated Active Scanning using OWASP ZAP

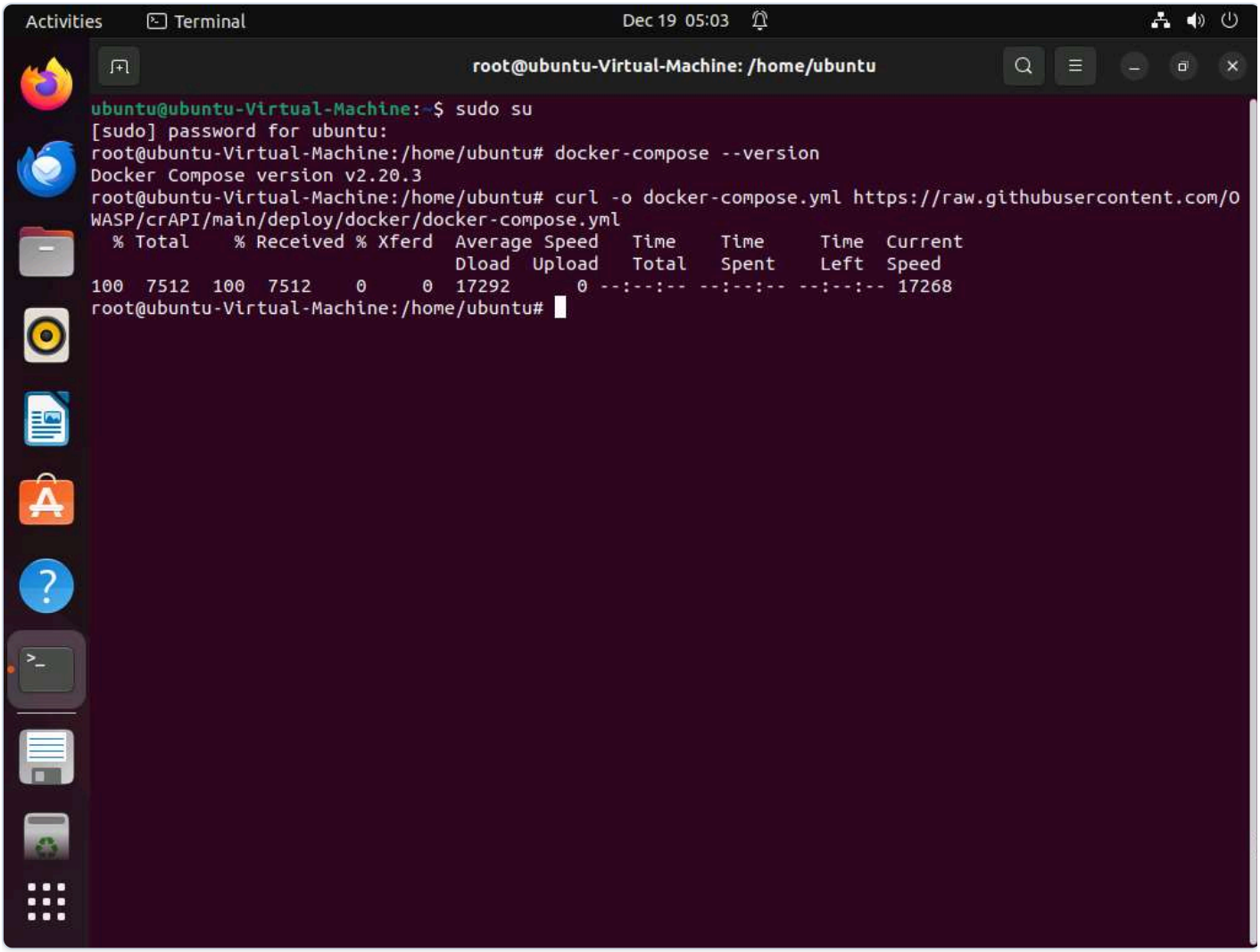
In this task, we initialize crAPI on Ubuntu, update port configurations in `docker-compose.yml`, launch OWASP ZAP on Parrot Security, register a user account, define session context, and execute an Active Scan to discover API vulnerabilities.

Lab Tasks

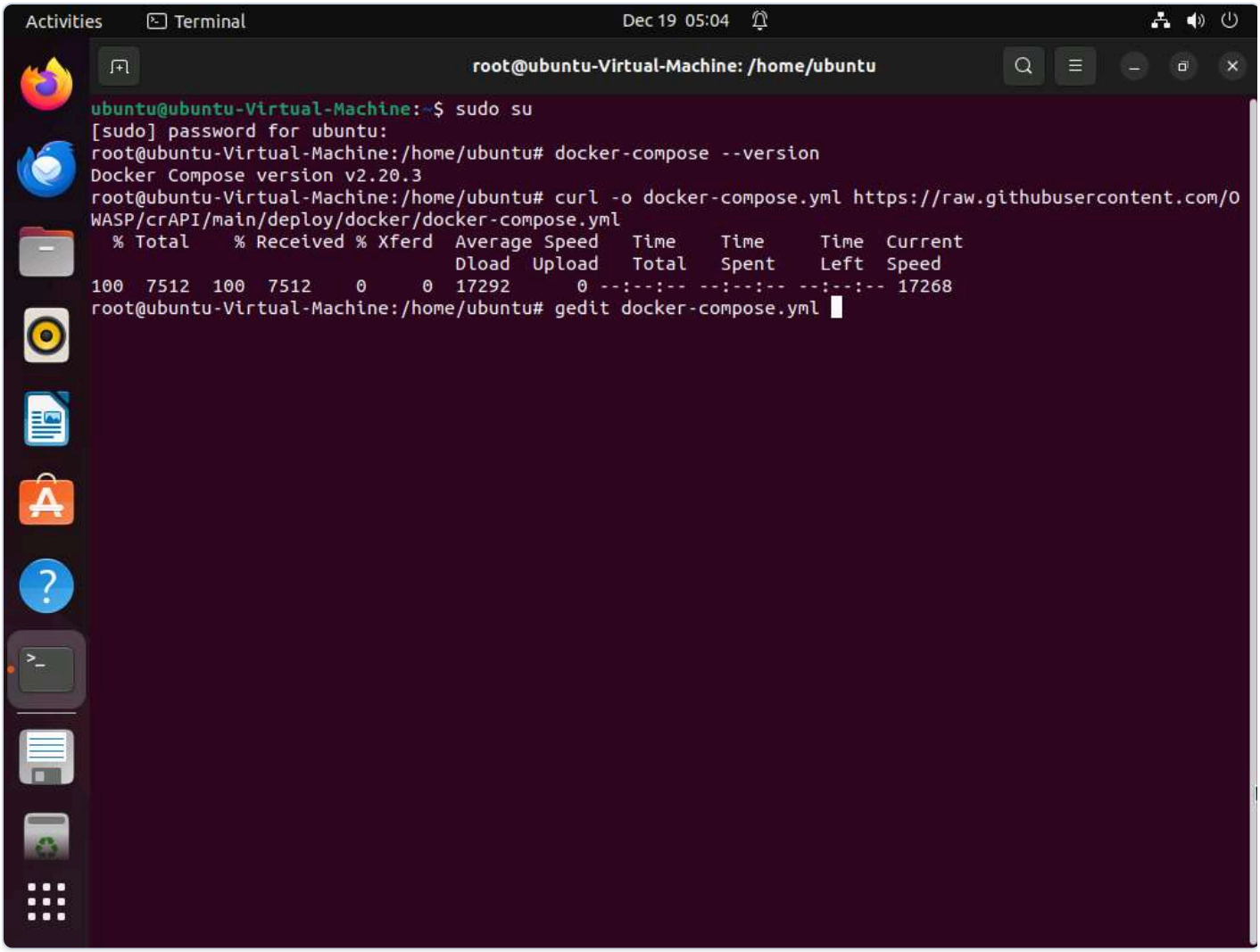
1. Switch to the **Ubuntu** machine (**ubuntu** / **toor**), open a terminal, and elevate to root (**sudo su**).
2. Verify Docker Compose installation:
   docker-compose --version

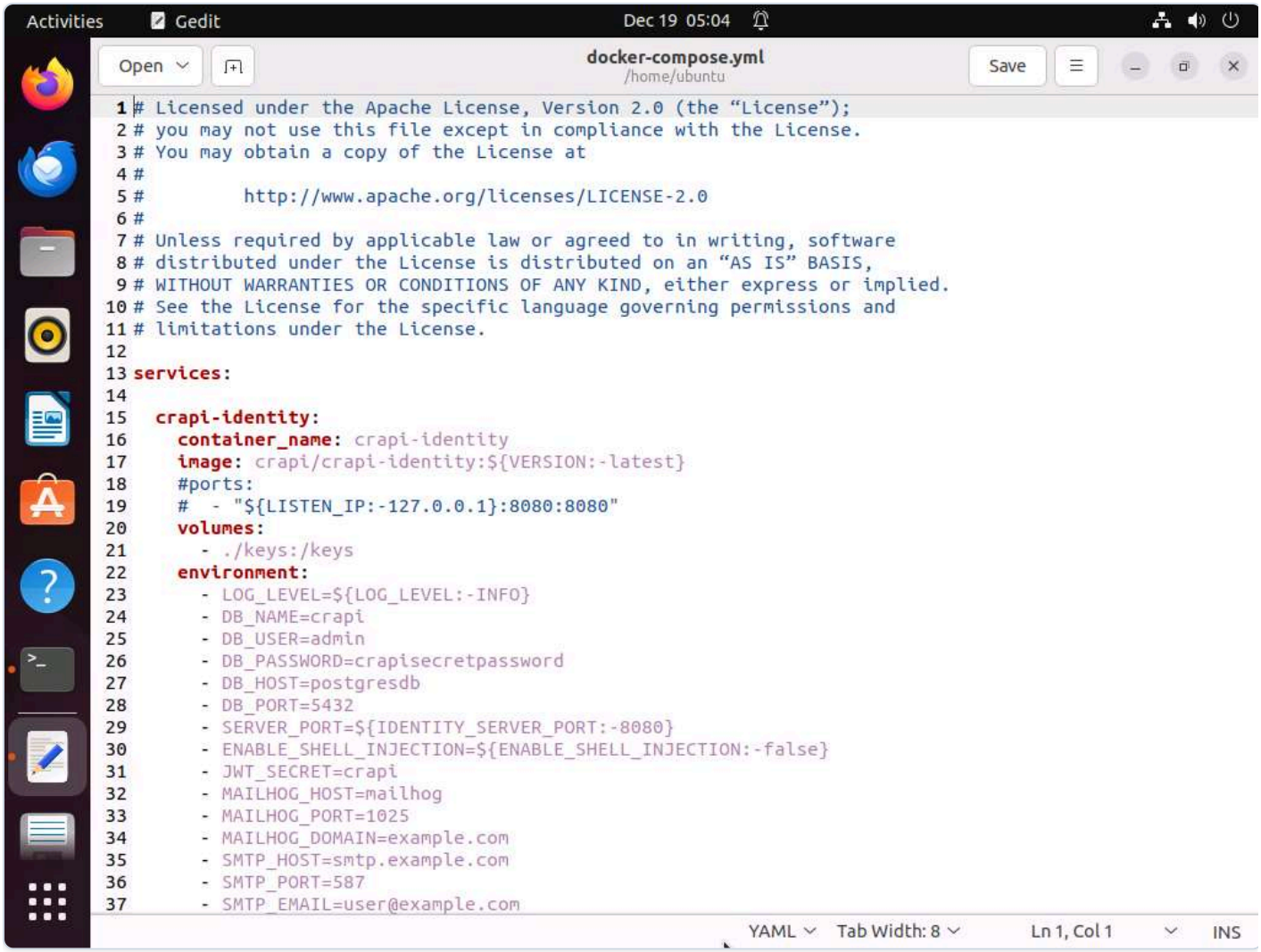


1. Download the official OWASP crAPI deployment compose file:
   curl -o docker-compose.yml https://raw.githubusercontent.com/OWASP/crAPI/main/deploy/docker/docker-compose.yml

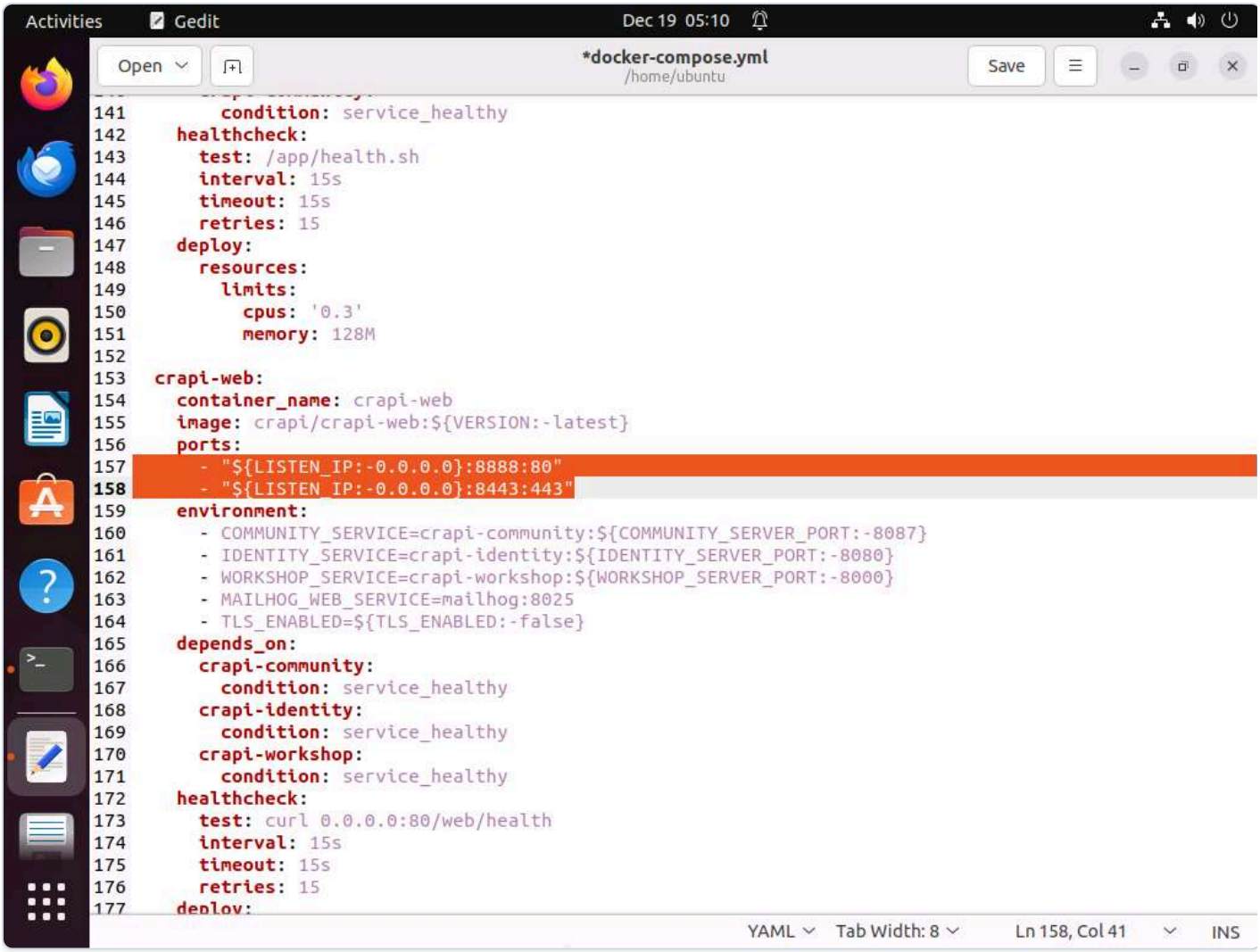


1. Open `docker-compose.yml` in gedit text editor:
   gedit docker-compose.yml

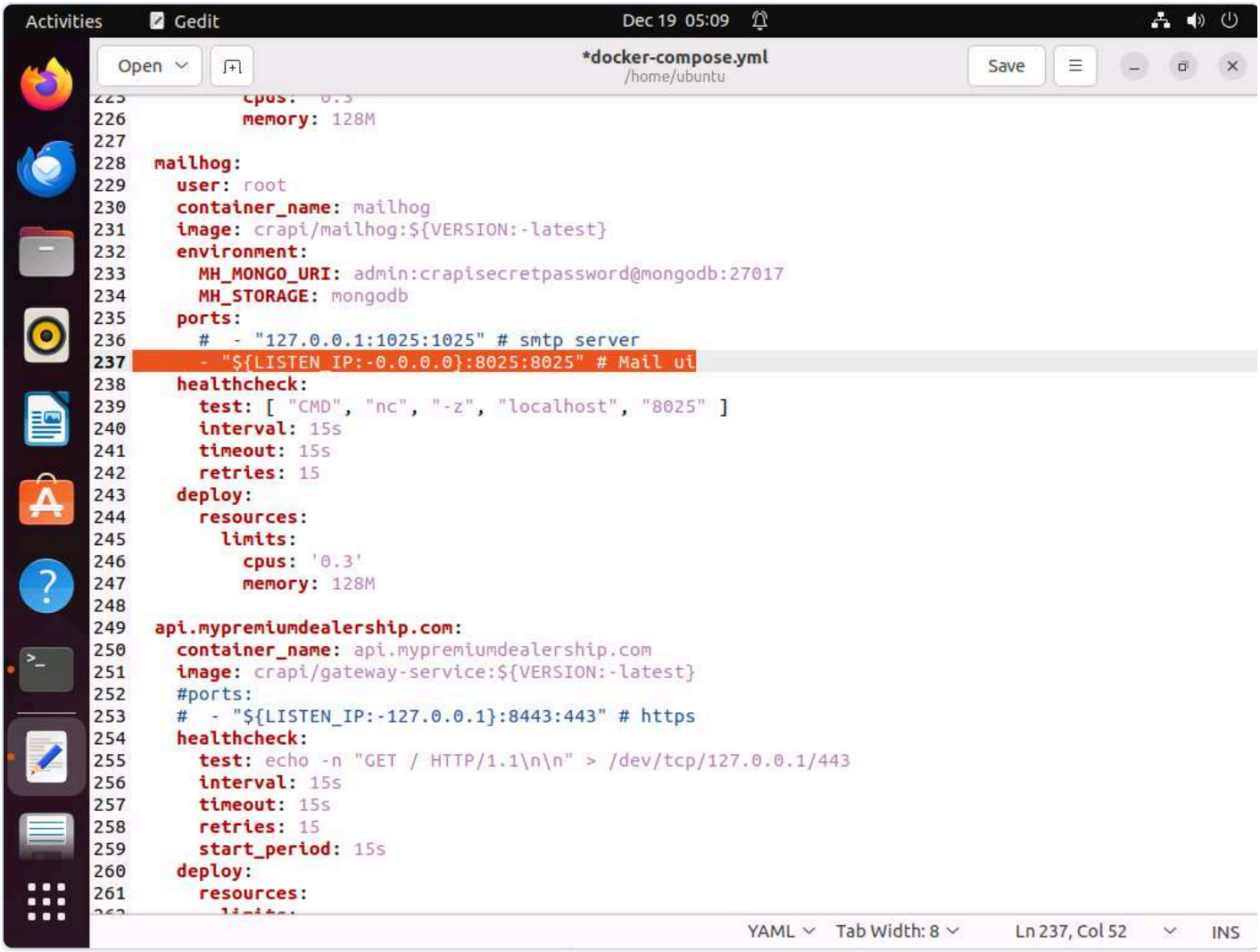

Activities
Terminal
Dec 19 05:04
root@ubuntu-Virtual-Machine: /home/ubuntu
ubuntu@ubuntu-Virtual-Machine:~$ sudo su
[sudo] password for ubuntu:
root@ubuntu-Virtual-Machine:/home/ubuntu# docker-compose --version
Docker Compose version v2.20.3
root@ubuntu-Virtual-Machine:/home/ubuntu# curl -o docker-compose.yml https://raw.githubusercontent.com/OWASP/crAPI/main/deploy/docker/docker-compose.yml
% Total % Received % Xferd Average Speed Time Time Time Current
Dload Upload Total Spent Left Speed
100 7512 100 7512 0 0 17292 0 --:--:-- --:--:-- --:--:-- 17268
root@ubuntu-Virtual-Machine:/home/ubuntu# gedit docker-compose.yml



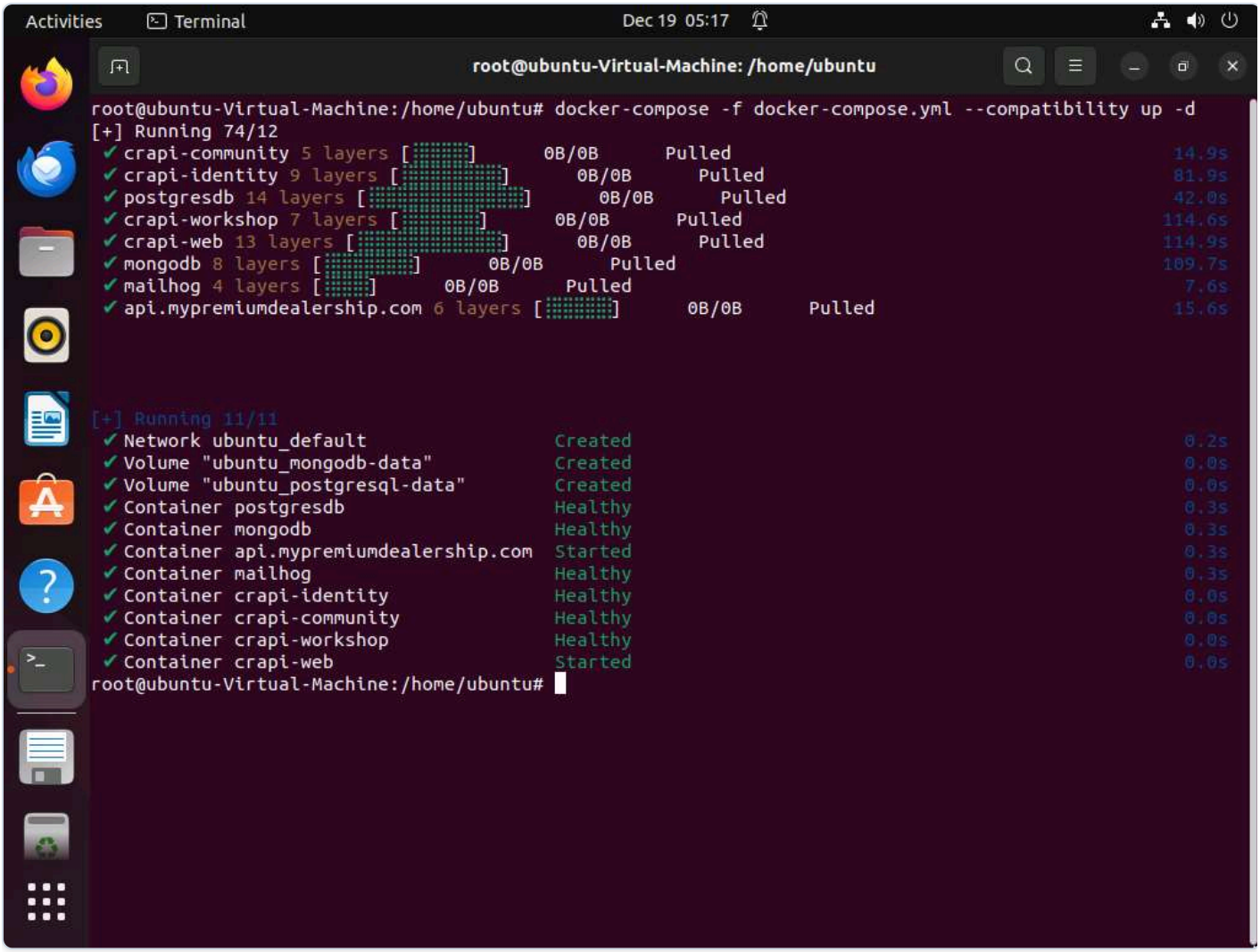
1. Modify the `crapi-web` service section to map port `8888:80` as shown in the manual.



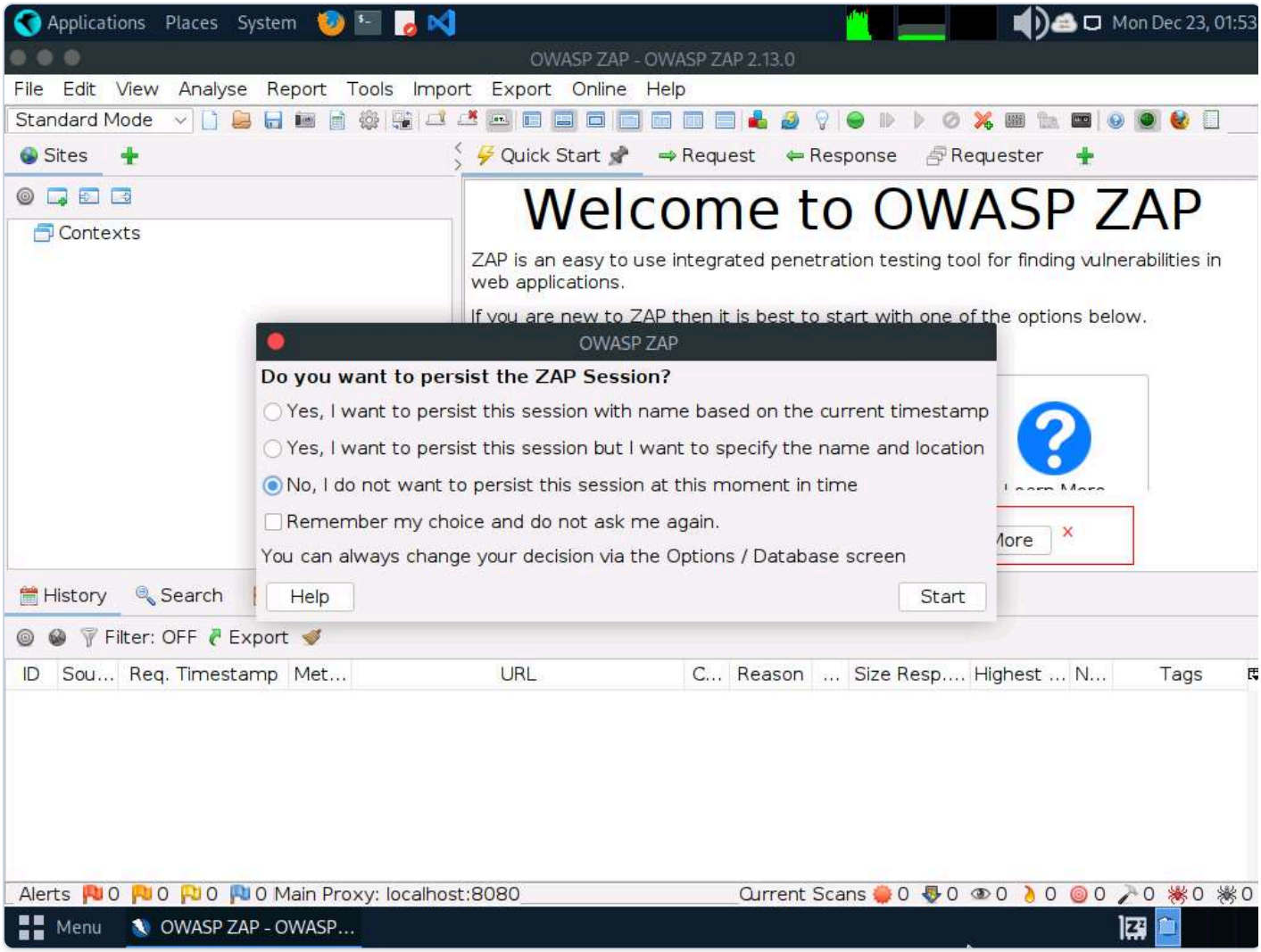
1. Scroll to the `mailhog` service section and adjust the port bindings accordingly.



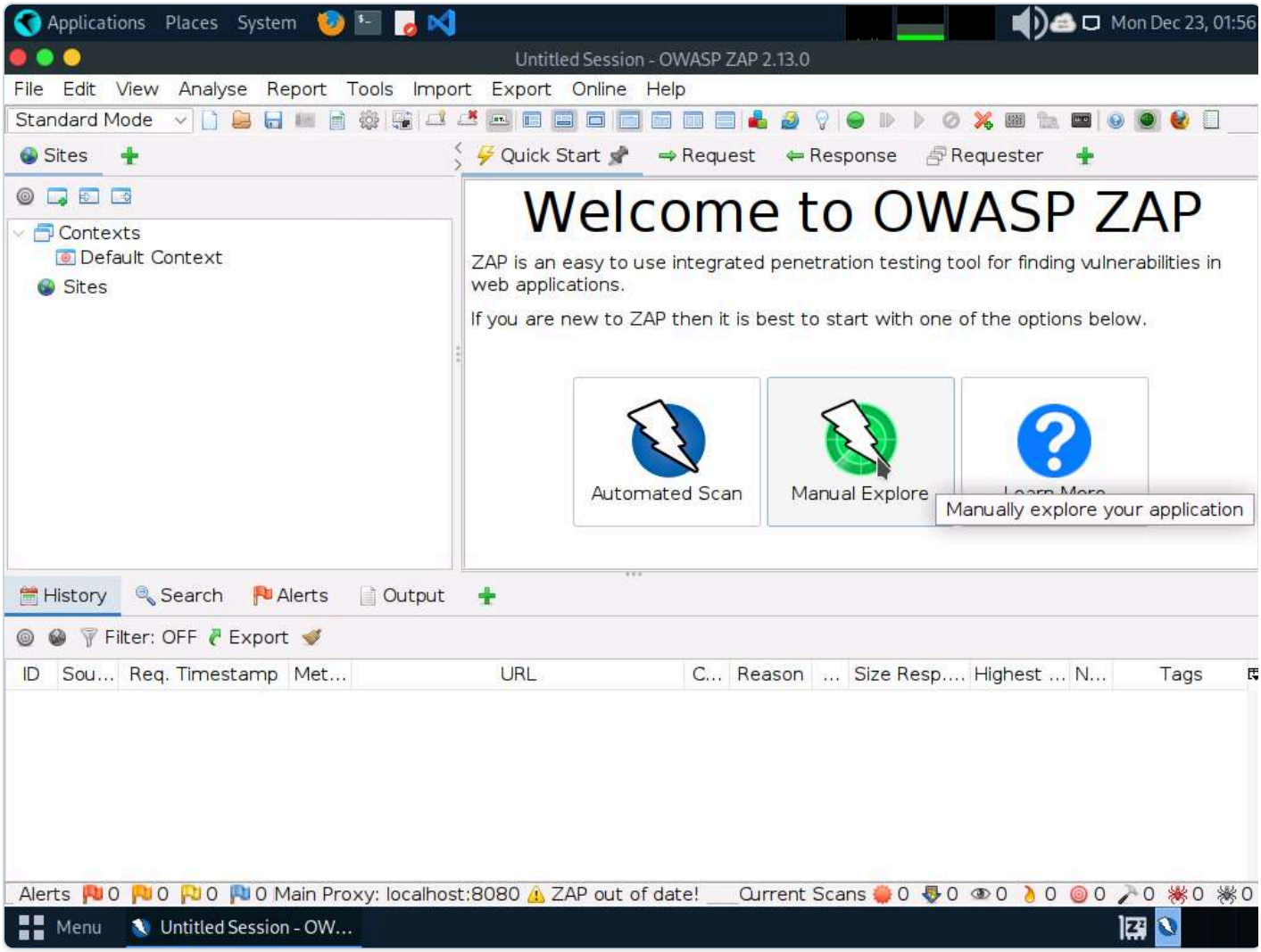
1. Save and close `docker-compose.yml`.
2. Start the crAPI microservices containers in detached mode:
   docker-compose -f docker-compose.yml --compatibility up -d

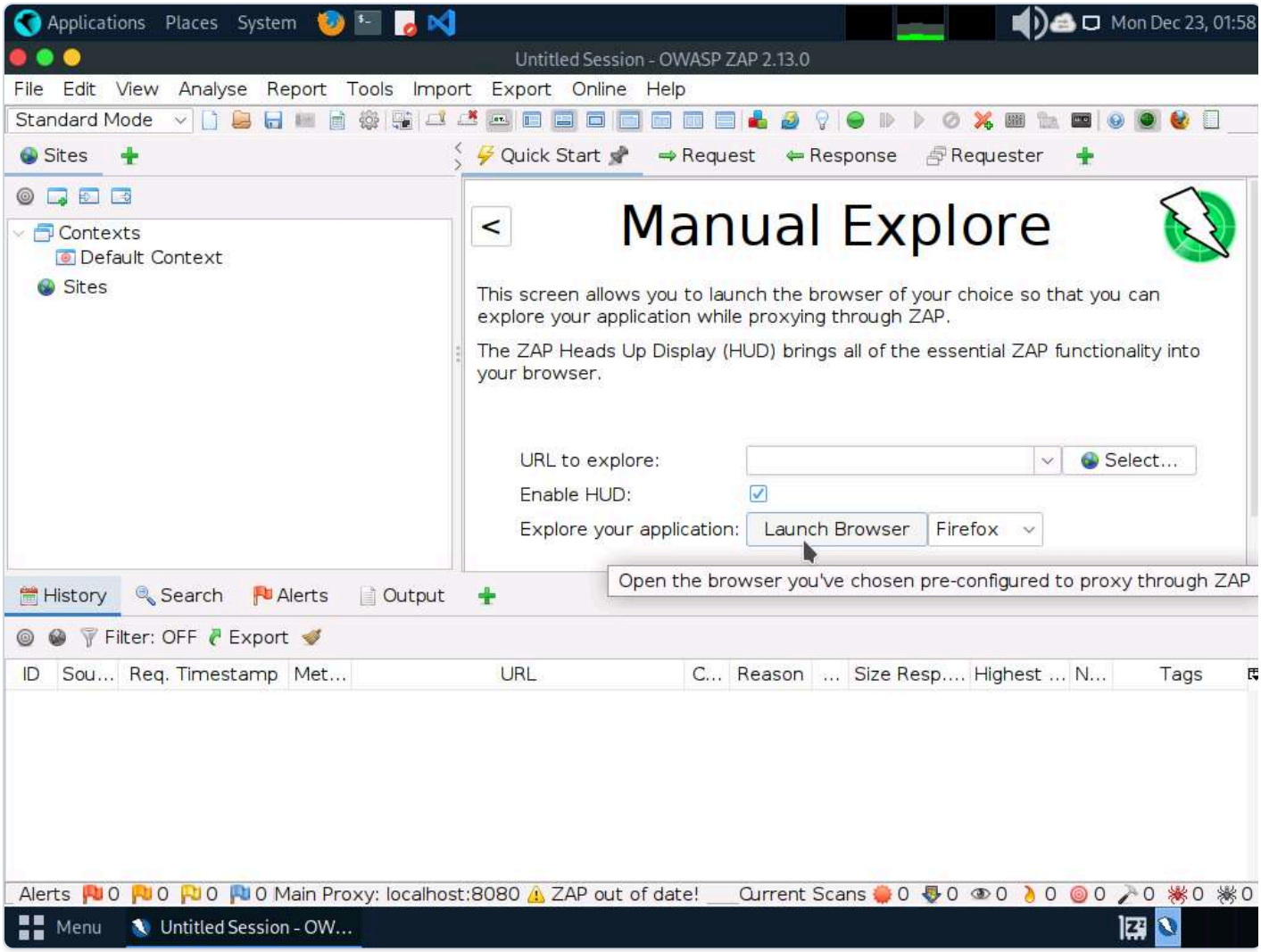


1. Switch to **Parrot Security** (**pentester** / **toor**). Launch **OWASP ZAP** from the applications menu.
2. Select "*No, I do not want to persist this session at this moment in time*" and click **Start**. Close any Manage Add-ons dialogs.

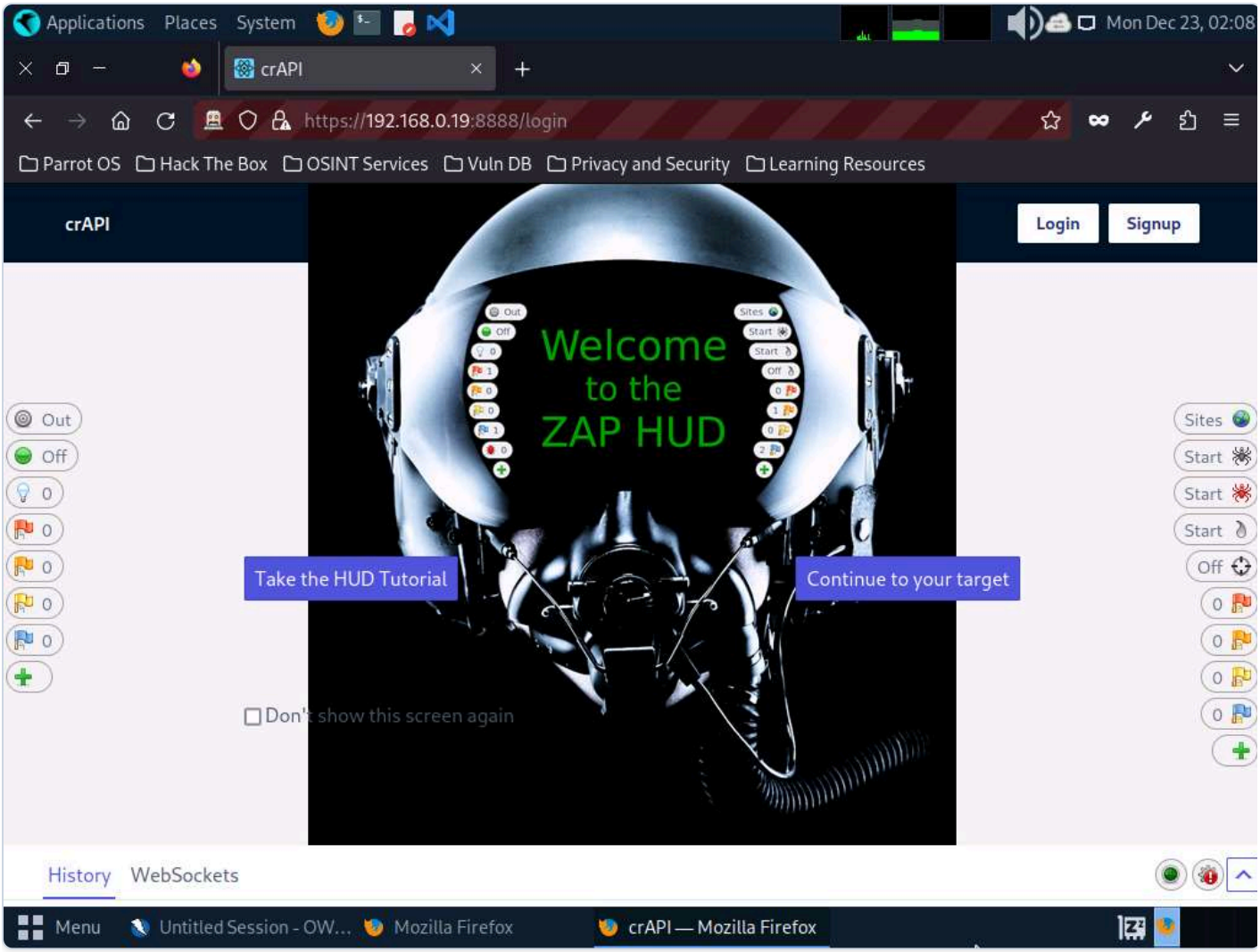


1. On the ZAP main workspace, click **Manual Explore** and then click **Launch Browser**.

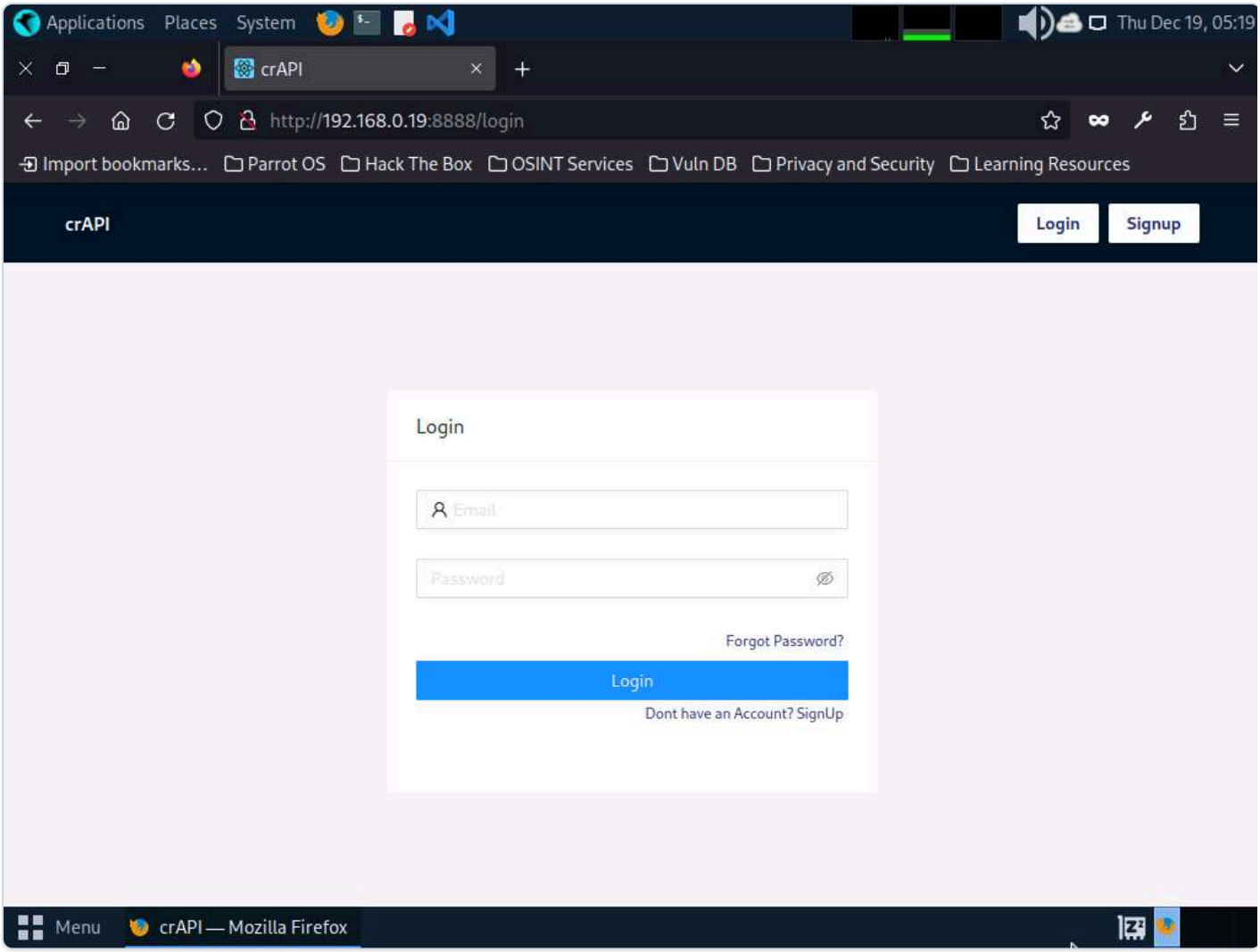

Applications Places System
Mon Dec 23, 01:56
Untitled Session - OWASP ZAP 2.13.0
File Edit View Analyse Report Tools Import Export Online Help
Standard Mode
Sites
Quick Start
Request
Response
Requester
Contexts
Default Context
Sites
Welcome to OWASP ZAP
ZAP is an easy to use integrated penetration testing tool for finding vulnerabilities in web applications.
If you are new to ZAP then it is best to start with one of the options below.
Automated Scan
Manual Explore
Manually explore your application
History
Search
Alerts
Output
Filter: OFF
Export
ID
Sou...
Req. Timestamp
Met...
URL
C...
Reason
...
Size Resp....
Highest ...
N...
Tags
Alerts 0 0 0 0 Main Proxy: localhost:8080 ZAP out of date! Current Scans 0 0 0 0 0 0 0 0
Menu
Untitled Session - OW...



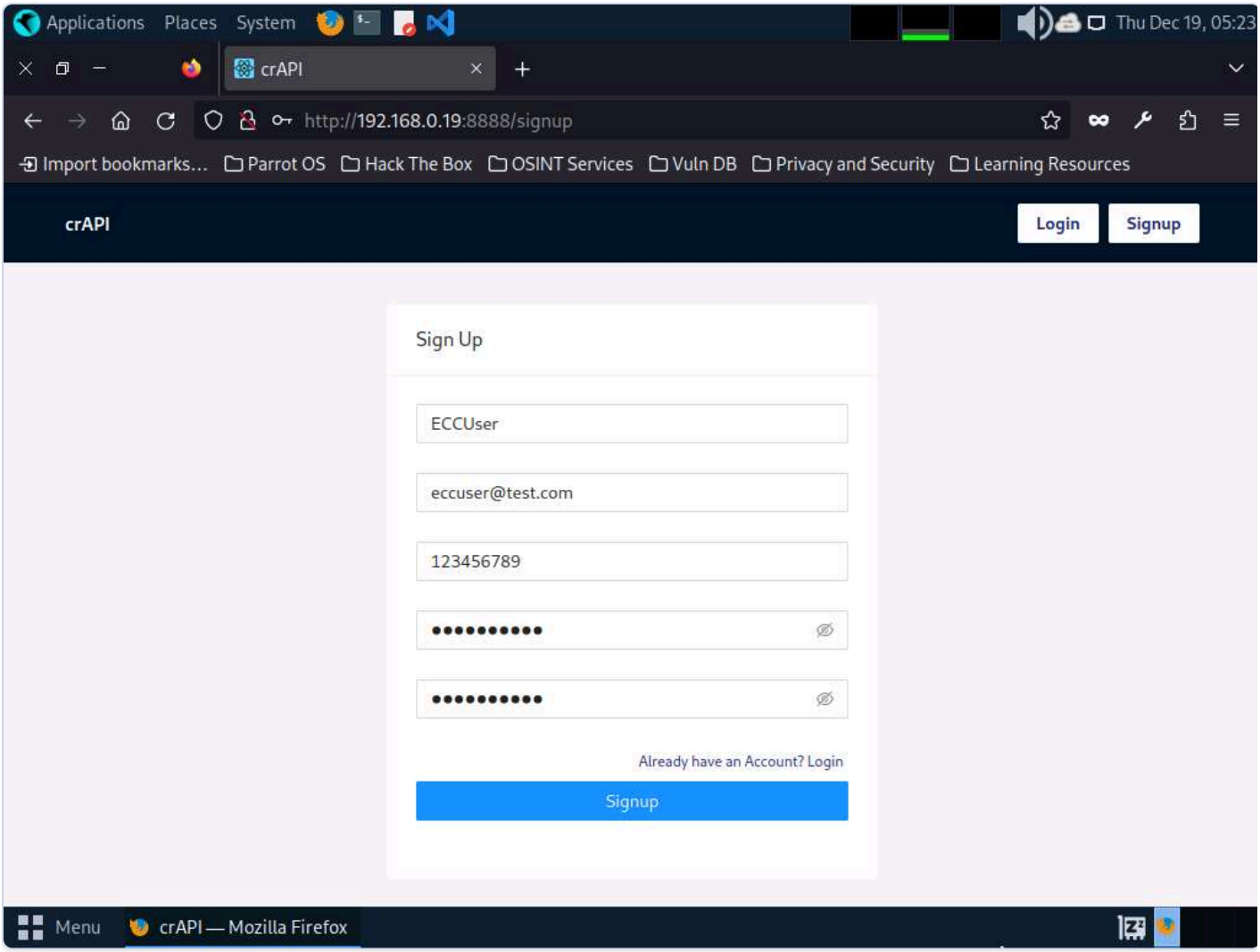
1. In the ZAP browser window, navigate to **http://192.168.0.19:8888** to open the crAPI web portal.



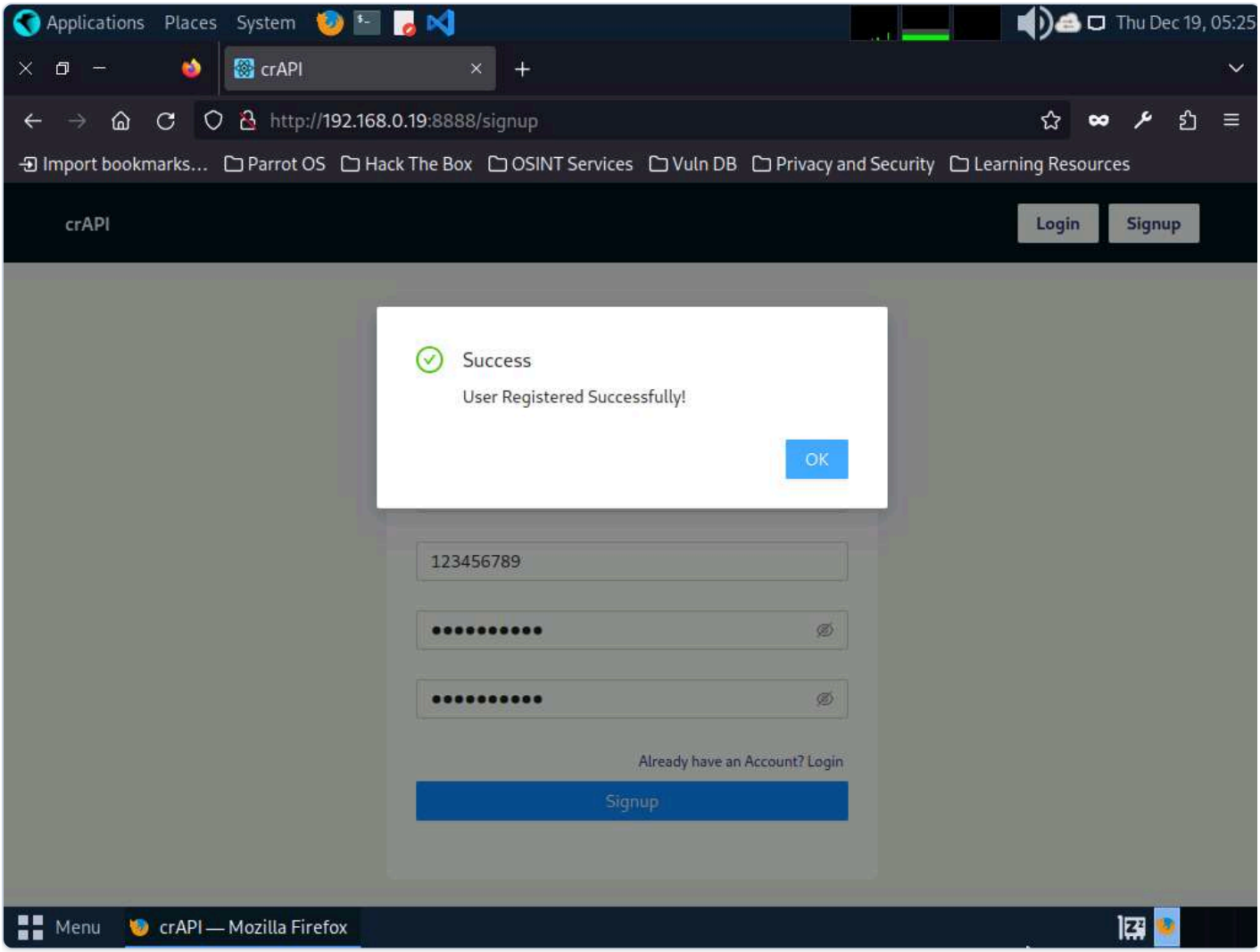
1. Click **Signup** to register a new user account.



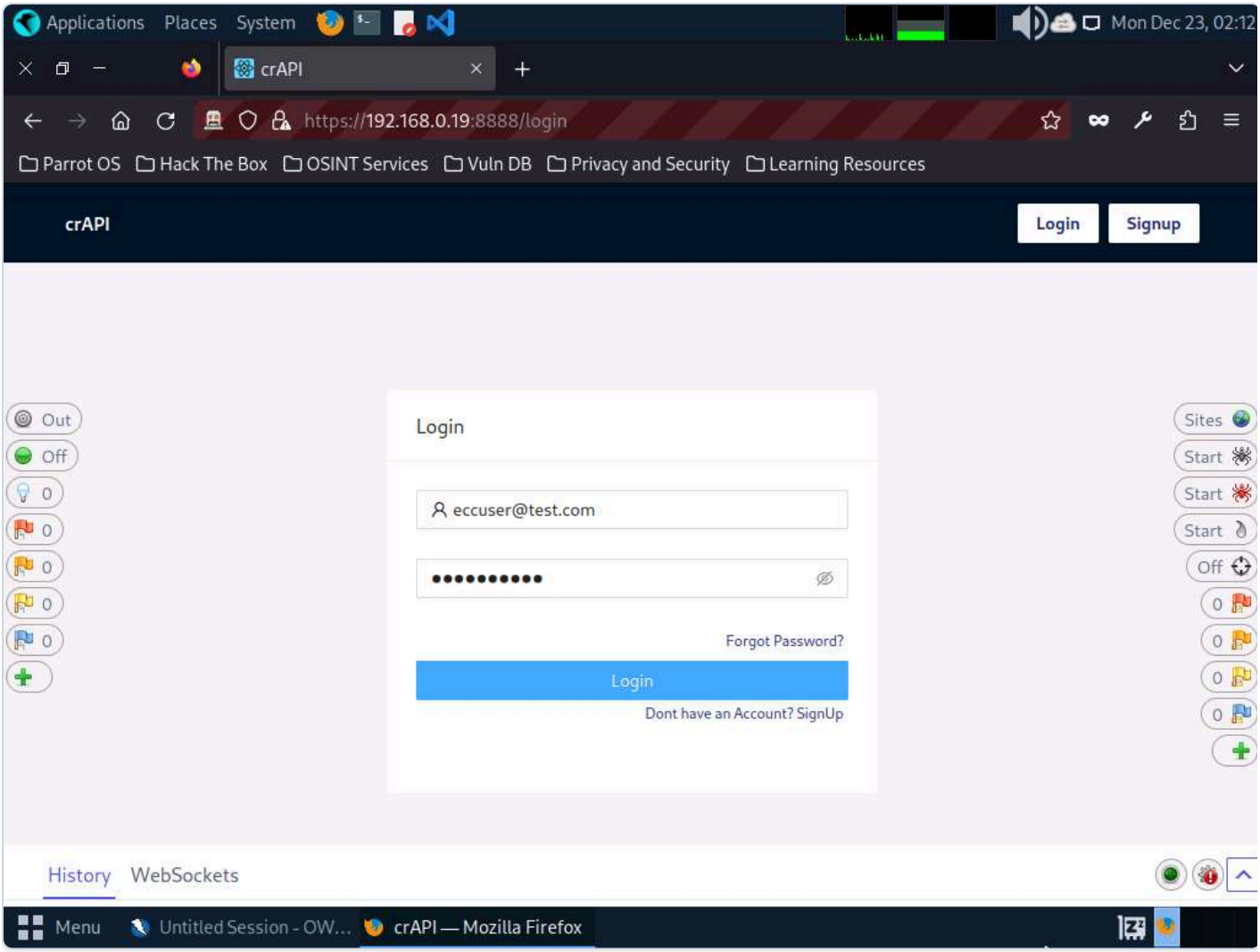
1. Complete the registration form details and click **Signup**.



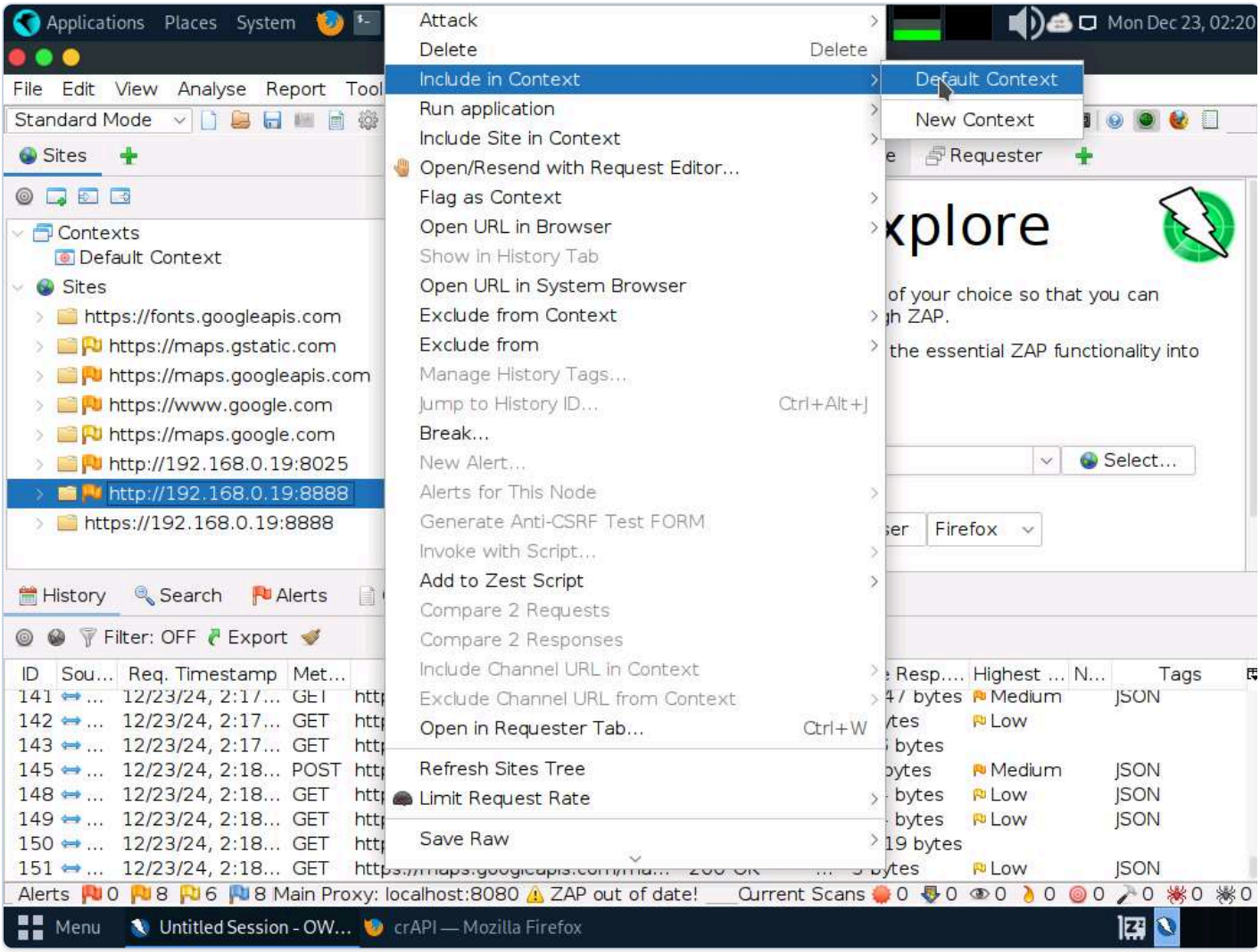
1. Click **OK** on the registration success confirmation dialog.



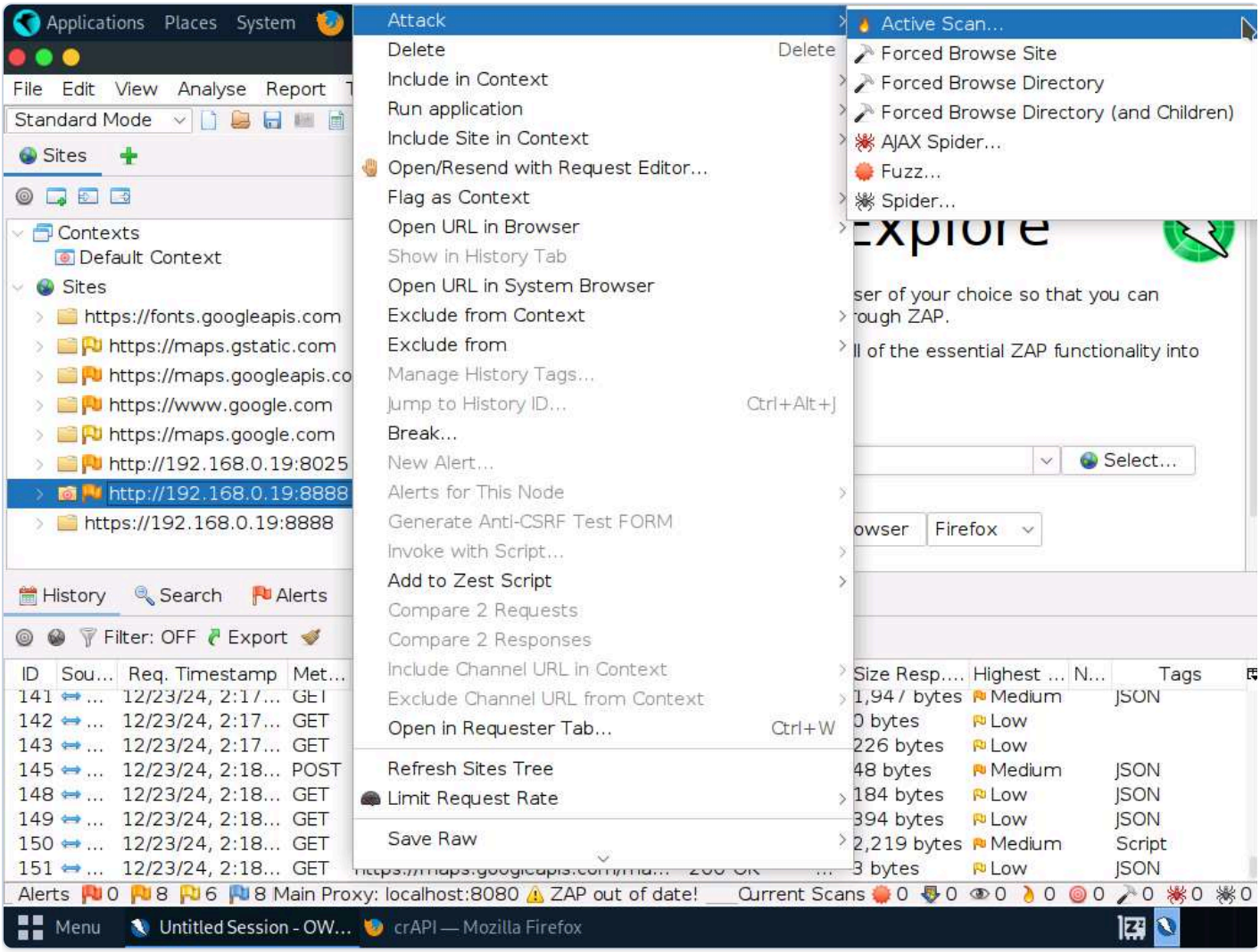
1. Log into crAPI with the newly registered user credentials.



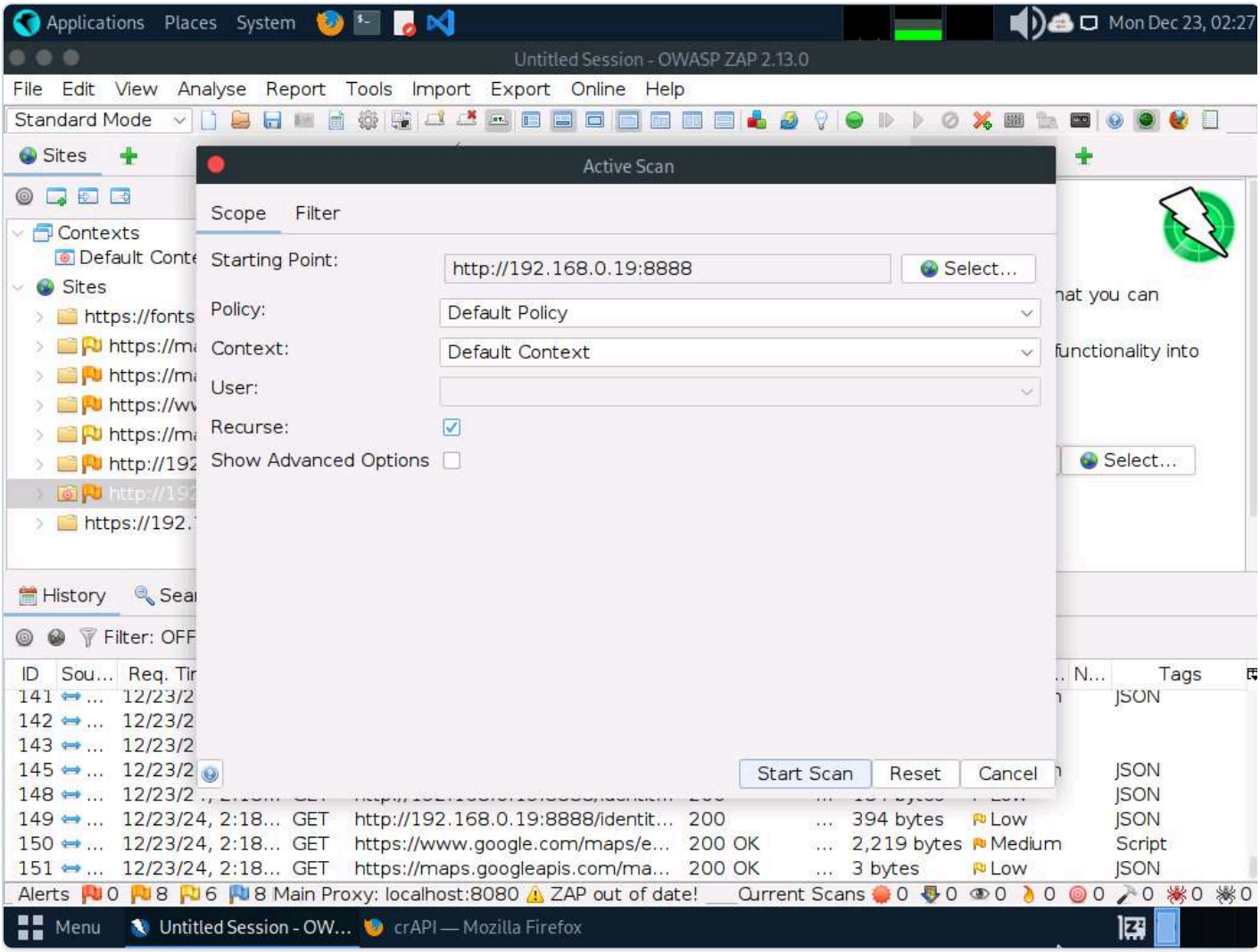
1. Explore the crAPI interface (click **Shop**, view items) to populate ZAP's site tree with authenticated API endpoints.
2. Return to ZAP, right-click the target site node under Sites, and select **Include in Context** $ ightarrow$ **Default Context**. Click **OK** in Session Properties.



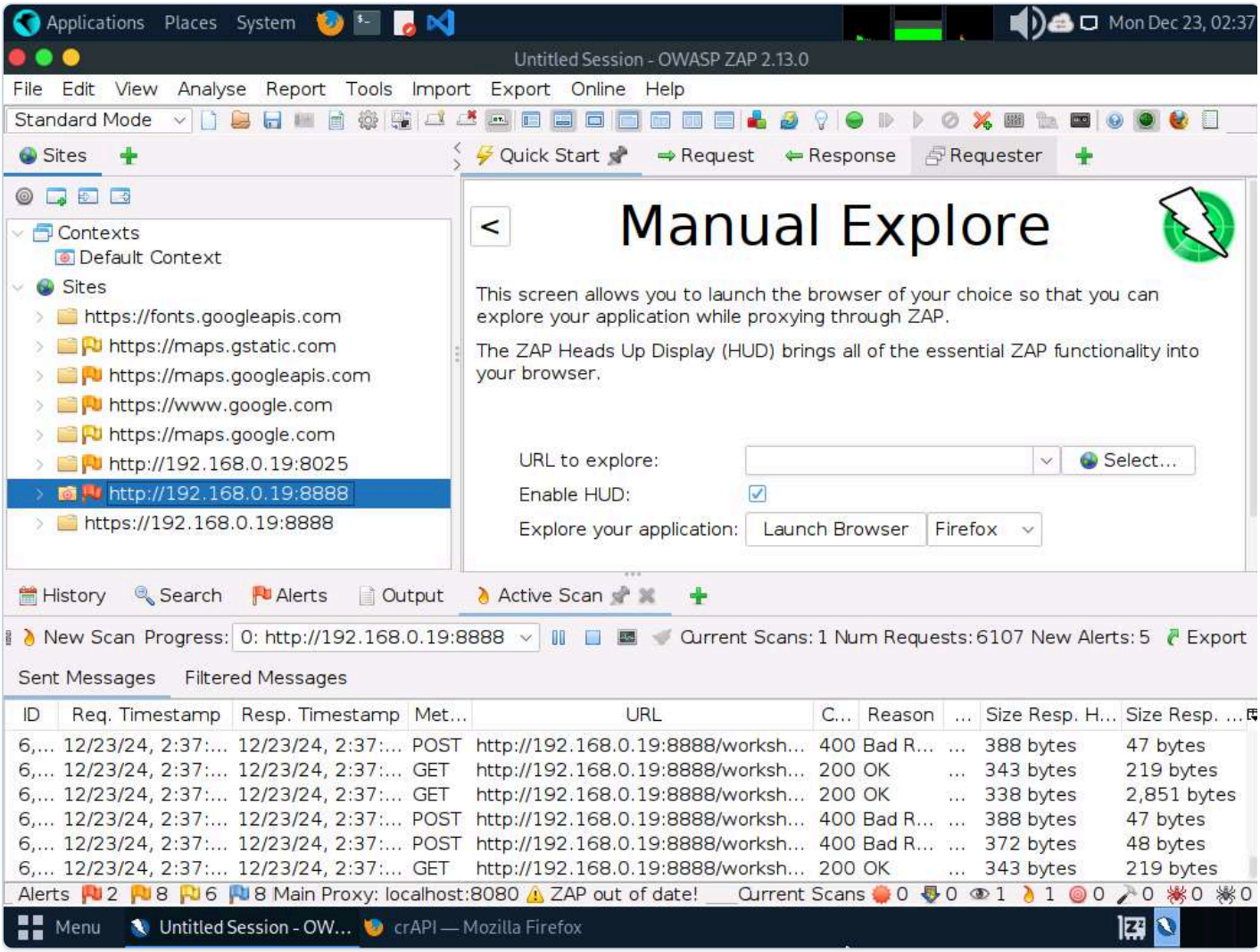
1. Right-click the target site node again and select **Attack** $ ightarrow$ **Active Scan**.



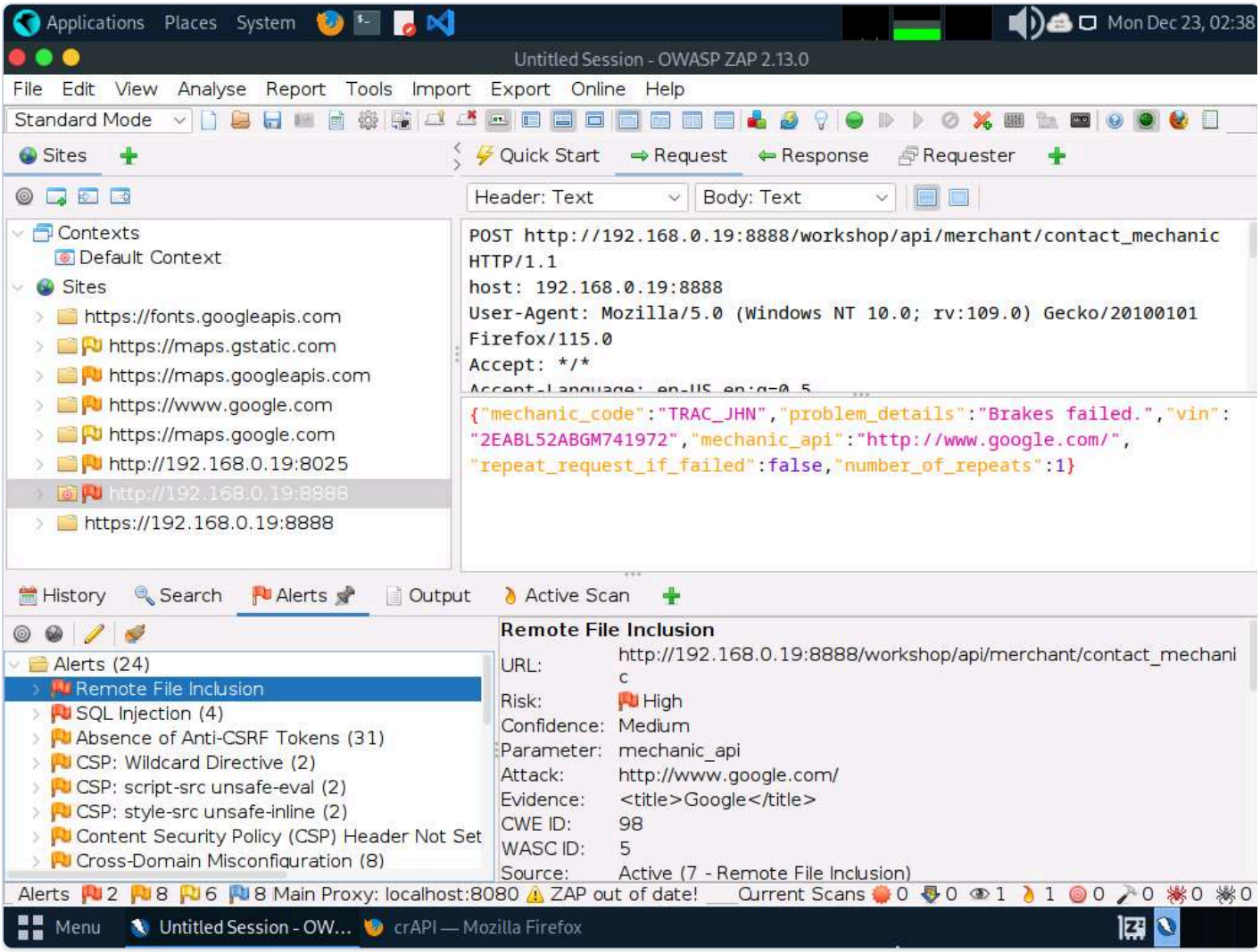
1. Confirm the target URL in the **Starting Point** field and click **Start Scan**.



1. Monitor progress under the **Active Scan** tab as ZAP tests API parameters and payloads.



1. When scanning completes, switch to the **Alerts** tab to examine discovered vulnerabilities, confirming identification of **Remote File Inclusion (RFI)**.



1. Close OWASP ZAP and Firefox windows.

This concludes the lab exercise.

IMPORTANT: ❓ **Question 6.3.1.1** Set up and execute crAPI on an Ubuntu machine, then access the API from a Parrot Security machine using the OWASP ZAP browser. Conduct a vulnerability scan to identify security flaws in the API. Specify the type of scan performed in this lab. [!SUCCESS] ✅ **Answer:** **Active scan**